

Blue Team Master Plan

Windows domain, administrator accounts, users and connected service servers (email, web, files). Part 1 is the checklist, Part 2 is how to do each item. Checkmarks save in this browser.

Golden rules

- Score = uptime. After every change run a scored-service test and send/receive a test email.
- Never change scoring or service account passwords, scoring-engine IPs, hostnames or IPs unless the rules allow it.
- Snapshot first, change one thing at a time, log every change with a time. Never clear event logs.
- Allow rules before default-deny. Disable and quarantine before deleting. Assume the red team is already inside.

Only 15 minutes? Snapshot, then admin and user passwords plus privileged groups, then firewall allow rules then default-deny, then kill unknown sessions, then tasks/services sweep, then close mail relay and check forwarding rules.

0 / 50 done

Reset

Part 1: Checklist

Phase 0: Prep and safety net ALL 0 to 10 min

- ☐ Read the rules: scored services, scoring IPs and accounts, forbidden actions
- ☐ Inventory every VM: role, OS, IP, listening ports, admins, installed software
- ☐ Snapshot every VM (clean baseline) and export firewall, security policy and GPOs
- ☐ Edit \$Config in Harden-Server.ps1: TeamIPs, ProtectedAccounts, ExtraTCPPorts, KeepServices
- ☐ Assign owners (DC, mail, users/workstations, hunter, scribe) and start the change log
- ☐ Run Harden-Server.ps1 as a dry run on each server and read the audit report

Phase 1: Identity, domain and administrator DC 10 to 30 min

- ☐ New unique passwords: Administrator, every Domain Admin, DSRM; then service accounts (not scoring), then users
- ☐ Audit privileged groups and remove unknown members (Domain/Enterprise/Schema Admins,

Administrators, Operators, DnsAdmins, GPU Creator Owners, Remote Desktop Users)

- ☐ Disable Guest, rename or disable built-in Administrator, give each teammate a named admin account
- ☐ Find and disable unknown, recently created or hidden accounts (including names ending in \$)
- ☐ Password policy (12+, complexity, history 24) and lockout (10 tries, 15 min)
- ☐ Kerberos/AD hygiene: AS-REP, SPN account passwords, delegation, MachineAccountQuota 0, DCSync rights, AdminSDHolder
- ☐ Log off unknown sessions

Phase 2: Network and attack surface ALL 20 to 45 min

- ☐ Firewall on for all profiles with allow rules first, then default-deny inbound and dropped-packet logging
- ☐ Every listening port mapped to a known process
- ☐ RDP: NLA, team IPs only, only needed users (or off). WinRM scoped or disabled
- ☐ Disable Print Spooler (esp. DC), Remote Registry, WebClient, Telnet, SNMP, SMBv1, PowerShell v2
- ☐ Uninstall remote-access and attack tools (TeamViewer, AnyDesk, VNC, netcat, Tor)
- ☐ DNS: zone transfers off, secure-only updates, MX, mail A, SPF and autodiscover records verified

Phase 3: Evict persistence, then repeat ALL 30 to 60 min

- ☐ Scheduled tasks outside \Microsoft\Windows with odd actions
- ☐ Services with binaries in Temp, Users, ProgramData or Public; Run/RunOnce keys; Winlogon Shell and Userinit
- ☐ Startup folders, WMI subscriptions, IFE0 debuggers, sethc/utilman replaced with cmd.exe
- ☐ Unknown processes and outbound connections; unsigned binaries in user-writable folders
- ☐ Shares (no Everyone Full Control), hosts file, proxy settings, rogue root certificates
- ☐ Defender exclusions reviewed (keep legit Exchange ones), full scan
- ☐ GPOs: logon/startup scripts, scheduled-task preferences, Restricted Groups, SYSVOL scripts
- ☐ Web roots checked for web shells

Phase 4: Email server MAIL

- ☐ Mail software patched (Exchange CU and SU, or latest hMailServer)
- ☐ No open relay; authenticated submission only; STARTTLS with a valid certificate

- Forwarding, inbox rules, transport rules and mailbox permissions audited
- Admin interfaces (ECP/EAC, remote PowerShell, hMailServer admin) limited to the team
- Unused protocols off (POP3/IMAP if not scored), VRFY/EXPN off, brute-force auto-ban on
- OWA/webmail: SSL required, no web shells in aspnet_client or auth folders
- Mail flow tested internal and external after every change

Phase 5: Users, workstations and other service servers USERS / SVC

- Every user accounted for; stale accounts disabled; scoring user left untouched
- Standard users are not local admins; local Administrators group audited on every machine (LAPS or unique local admin password)
- Phase 2 and 3 sweeps run on every member server and workstation
- IIS/web: directory browsing off, anonymous auth off where unneeded, SSL required, X-Powered-By removed
- File server: share and NTFS permissions reviewed, SMB signing on
- Database/FTP/other: default credentials changed, firewall scoped to the app server, anonymous FTP off

Phase 6: Protocols, patching and logging ALL

- NTLMv2 only, no LM hash, no anonymous enumeration, SMB signing required
- WDigest off, LSA protection (test), LLMNR, mDNS, NetBIOS and WPAD off
- ZeroLogon enforcement; LDAP signing and channel binding (test mail and apps first)
- UAC on, AutoPlay off, Remote Assistance off, user rights trimmed
- Windows updates installed in order: DC, mail, others (check rules allow patching)
- Advanced audit policy, command-line and PowerShell logging, 1 GB security log

Phase 7: Ongoing loop and incident response TEAM

- Sweep every 15 to 30 minutes (users, groups, tasks, services, connections, key event IDs)
- Test scored services after every change and every hour regardless
- Back up hardened GPOs, firewall and mail data somewhere the red team cannot reach
- On a compromise: contain, record evidence and time, remove the foothold and its cause, retest, write it up

Part 2: Detailed plan

▼ Phase 0: Prep and safety net

1. **Owners.** One person per box (DC, mail, users/workstations), one hunter who watches logs and runs sweeps, one scribe for the change log. This stops two people changing the same setting.

2. **Inventory** on each VM:

```
Get-CimInstance Win32_ComputerSystem | select Name,Domain,DomainRole    # 4 or 5 = DC
netstat -ano | findstr LISTENING
Get-Service | ? Status -eq Running
net localgroup administrators
```

3. **Snapshot** every VM in the hypervisor and name it clean-baseline plus the time. If you cannot: System State backup on the DC and mail data, then

```
netsh advfirewall export C:\Blue\fw_original.wfw
secedit /export /cfg C:\Blue\secpol_original.cfg
```

and GPMC, Group Policy Objects, Back Up All.

4. **Dry run.** Fill in `$Config` first (put every scoring and mail service account in ProtectedAccounts). Then:

```
Set-ExecutionPolicy Bypass -Scope Process -Force
.\Harden-Server.ps1          # changes nothing; read C:\Blue\audit_report.txt
```

► Phase 1: Identity, domain and administrator

► Phase 2: Network and attack surface

► Phase 3: Evict persistence (repeat often)

► Phase 4: Email server

► Phase 5: Users, workstations and other service servers

► Phase 6: Protocols, patching and logging

► Phase 7: Ongoing loop and incident response

